

RAPORT INCYDENTU BEZPIECZEŃSTWA

Security Incident Report

Analiza wiadomości phishingowej

Ćwiczenie Blue Team — analiza artefaktu .eml

Analitik: Bartłomiej Kapała

Data analizy: 26.03.2026

Legenda: [FAKT] wynika bezpośrednio z artefaktu | [PRZYPUSZCZENIE] interpretacja niepewna | [BRAK DANYCH] czego nie ma w dowodach

0. Metryka analizy (Provenance)

Analizowany artefakt	training_phishing_with_detailed_headers.eml
SHA256 artefaktu	e5ceef8d2dcae0cb57c76a3dbadb5239335088b5282baccade0016cd0a29e254
Analitik	Bartłomiej Kapała
Data analizy	26.03.2026
Klasyfikacja	Ćwiczenie treningowe (nagłówek X-Training-Only: true)
Narzędzia	Python (email, hashlib), analiza nagłówków ręczna

[FAKT] Artefakt jest jawnie oznaczony jako treningowy; wszystkie domeny w zakresie .invalid, adresy IP w bloku dokumentacyjnym RFC 5737. Analiza ma charakter laboratoryjny.

1. Executive Summary

W dniu 26.03.2026 o godz. 09:14 UTC system pocztowy laboratorium odebrał wiadomość zaklasyfikowaną jako **phishing o tematyce finansowej** (payment exception). Wiadomość podszywała się pod „Northbridge Finance Portal” i zawierała **załącznik HTML** (Payment Review Portal.html) jako wektor nakłaniający odbiorcę do interakcji.

[FAKT] Wiadomość przeszła uwierzytelnienie SPF, DKIM i DMARC (wszystkie PASS) z domeny northbridge-finance.invalid.

[PRZYPUSZCZENIE] Wynik PASS oznacza albo wysyłkę z legalnej infrastruktury domeny, albo nadużycie zaufanej domeny. Brak dowodów rozstrzygających, które z dwojga.

[BRAK DANYCH] Nie ma dowodów, że odbiorca otworzył załącznik, ani że doszło do kompromitacji hosta lub konta.

Status: Contained — pending validation. **Severity:** Medium (uzasadnienie w sekcji 8).

2. Opis incydentu

Typ incydentu	Phishing (Spearphishing Attachment)
Data/godzina odbioru	26.03.2026 09:14:18 UTC
Źródło wykrycia	Analiza artefaktu .eml (ćwiczenie)
Severity	Medium
Status	Contained — pending validation
Odbiorca (ofiara)	analyst@example.invalid
Infrastruktura nadawcy	198.51.100.24 (mx1), 198.51.100.18 (webout01)

Krótki opis: Wiadomość o charakterze socjotechnicznym, wykorzystująca tematykę finansową i poczucie pilności, dostarczyła do skrzynki użytkownika załącznik HTML. Celem było nakłonienie odbiorcy do jego otwarcia. W dostarczonym artefakcie załącznik jest statyczny i pozbawiony aktywnej zawartości.

3. Chronologia zdarzeń

[FAKT] Timeline ograniczono wyłącznie do zdarzeń potwierdzonych nagłówkami wiadomości (Received chain czytany od dołu do góry).

Czas (UTC)	Zdarzenie	Źródło (nagłówek)
09:14:10	Utworzenie wiadomości	Date:
09:14:12	webout01 → mx1 nadawcy (.18 → .24)	dolny Received:
09:14:18	Odbiór przez gateway laboratorium	górny Received:

[BRAK DANYCH] Świadomie NIE ujęto: kliknięcia, otwarcia załącznika, detekcji SIEM, izolacji hosta — żadne z tych zdarzeń nie ma potwierdzenia w dostarczonych artefaktach. Ich weryfikacja wymagałaby logów Windows/EDR/SIEM spoza zakresu laboratorium.

4. Analiza techniczna

4.1 Infrastruktura nadawcy

- **[FAKT]** 198.51.100.24 — mx1.mailer.northbridge-finance.invalid (serwer graniczny nadawcy)
- **[FAKT]** 198.51.100.18 — webout01 / X-Originating-IP (host generujący wiadomość)
- **[FAKT]** Oba adresy w bloku 198.51.100.0/24 = TEST-NET-2 (RFC 5737), zakres dokumentacyjny, nierutowalny.

4.2 Tożsamość nadawcy

- **[FAKT]** Visible From: billing@northbridge-finance.invalid
- **[FAKT]** Return-Path / envelope: bounce+48291@mailer.northbridge-finance.invalid
- **[FAKT]** Reply-To: support@northbridge-finance.invalid
- **[PRZYPUSZCZENIE]** Rozbieżność subdomen (From na domenę głównej, envelope na mailer.) jest typowa dla systemów bulk-mail; nie jest sama w sobie dowodem złośliwości.

4.3 Uwierzytelnienie (SPF/DKIM/DMARC)

- **[FAKT]** SPF: pass (198.51.100.24 autoryzowany dla mailer.northbridge-finance.invalid)
- **[FAKT]** DKIM: pass (header.d=northbridge-finance.invalid, selektor nb2026)
- **[FAKT]** DMARC: pass (action=none)
- **[FAKT]** Podpis DKIM i bh w artefakcie to placeholderzy (TRAININGONLYSIGNATUREVALUE...) — potwierdza charakter laboratoryjny.

4.4 Analiza załącznika (zweryfikowana obliczeniem)

- **[FAKT]** Nazwa: Payment Review Portal.html, rozmiar 902 B (zdekodowane z base64)
- **[FAKT]** SHA256: 26efc31c092e7d3ddcfe5a2504294f6f6a820cef30f004957ed5b7735d0e90d6
- **[FAKT]** MD5: c2c82004f13138241db139cb586ff1c8
- **[FAKT]** Metoda: hash obliczony z realnie zdekodowanego payloadu (Python email+hashlib) ZGADZA SIĘ z hashem w nagłówku X-Training-Attachment-SHA256. Integralność potwierdzona.
- **[FAKT]** Zawartość: statyczny HTML bez skryptów, formularzy i pól logowania — w tym artefakcie benign. W realnym phishingu tu byłby formularz credential harvesting.

4.5 Zachowanie przeciwnika (socjotechnika)

- **[FAKT]** Tematyka finansowa + numer referencyjny (NB-48291) budujący wiarygodność
- **[FAKT]** Wywołanie pilności („unable to reconcile a recent payment”)
- **[FAKT]** Ogólne powitanie („Hello”) — brak personalizacji
- **[FAKT]** Lure oparty na załączniku, nie na linku

5. Mapowanie do MITRE ATT&CK

[FAKT] T1566.001 — Phishing: Spearphishing Attachment (Initial Access). Uzasadnienie: wiadomość zawiera załącznik jako wektor dostępu; technika zakłada wysyłkę spearphishingu z załącznikiem w celu uzyskania dostępu do systemów ofiary.

[PRZYPUSZCZENIE] T1204.002 — User Execution: Malicious File (Execution). Hipoteza aktywna tylko, gdyby użytkownik otworzył załącznik. BRAK DANYCH potwierdzających wykonanie.

[BRAK DANYCH] Persistence, Command and Control, Credential Access — brak jakichkolwiek dowodów w artefakcie. Nie mapowano.

Uwaga: technika T1056 (Input Capture) NIE ma zastosowania — dotyczy keyloggingu, nie credential harvesting przez stronę. Świadomie pominięta.

6. Wskaźniki kompromitacji (IOC)

[FAKT] Wszystkie IOC skopiowano znak w znak z artefaktu i zweryfikowano. Jedna, spójna pisownia domeny.

Typ	Wartość	Uwaga
Domena	northbridge-finance.invalid	TLD .invalid (treningowy)
Subdomena	mailer.northbridge-finance.invalid	envelope / mx
IP nadawcy (mx1)	198.51.100.24	RFC 5737 dokumentacyjny
IP nadawcy (webout01)	198.51.100.18	RFC 5737 dokumentacyjny
Nazwa pliku	Payment Review Portal.html	załącznik
SHA256 załącznika	26efc31c...d0e90d6	pełny hash w sekcji 4.4
MD5 załącznika	c2c82004f13138241db139cb586ff1c8	—
Subject	[TRAINING ONLY] Payment Exception Notice - Ref NB-48291	sygnatura kampanii

[BRAK DANYCH] Registry keys, scheduled tasks, procesy, ścieżki plików — N/A, żadnych artefaktów hosta.

7. Analiza przyczyn źródłowych (RCA)

Bezpośrednia przyczyna: dostarczenie do skrzynki użytkownika wiadomości phishingowej z załącznikiem HTML, która przeszła kontrole uwierzytelnienia (SPF/DKIM/DMARC PASS) i nie została zatrzymana na bramie.

[BRAK DANYCH] Nie potwierdzono, czy użytkownik otworzył załącznik — dalszy łańcuch zdarzeń pozostaje niepotwierdzony.

Przyczyny systemowe (potencjalne):

- Uwierzytelnienie e-mail PASS nie chroni przed treścią socjotechniczną — potrzebna analiza behawioralna treści.
- Brak sandboxingu / detonacji załączników HTML na bramie pocztowej.
- Możliwy brak korelacji zdarzeń e-mail z SIEM i widoczności po stronie endpointa.

8. Impact

Wpływ techniczny

- **[FAKT]** Brak potwierdzonej kompromitacji hosta lub konta.
- **[PRZYPUSZCZENIE]** Potencjalne ryzyko credential harvesting, GDYBY realny wariant zawierał formularz (w tym artefakcie nie zawiera).

Wpływ biznesowy

- **[PRZYPUSZCZENIE]** Ryzyko wycieku danych / środków w razie skutecznego phishingu na realnym wariancie kampanii.
- **[FAKT]** Koszt operacyjny analizy i reakcji SOC.

Uzasadnienie Severity = Medium: wektor realny (phishing dotarł do skrzynki), ale brak potwierdzonego wykonania i brak aktywnej złośliwej zawartości w artefakcie. Nie High (brak potwierdzonej kompromitacji), nie Low (dostarczenie się powiodło).

9. Działania naprawcze

Containment

- Usunięcie wiadomości ze skrzynki odbiorcy (i wyszukanie identycznych po Subject/hash).
- Dodanie IOC (domena, hash) do blocklist bramy pocztowej i EDR.

Eradication

- **[FAKT]** Brak potwierdzonego malware — brak artefaktów do usunięcia. Ewentualna weryfikacja endpointa odbiorcy.

Recovery

- Brak potrzeby przywracania systemu; wzmożony monitoring konta odbiorcy przez ustalony okres.

10. Rekomendacje

1. Wdrożyć sandboxing / detonację załączników (w tym HTML) na bramie pocztowej.
2. Dodać regułę detekcji: załącznik HTML + tematyka finansowa + wording pilności.
3. Skorelować zdarzenia e-mail z SIEM (dostawa, klik, wykonanie) dla pełnej widoczności.
4. Szkolenia phishing awareness ukierunkowane na lure załącznikowy.
5. Rozważyć DMARC z polityką reject dla domen podszywających oraz weryfikację display-name.

11. Wnioski / Lessons Learned

- SPF/DKIM/DMARC PASS nie oznacza, że wiadomość jest bezpieczna — potwierdza tylko pochodzenie, nie intencję.
- Received chain czyta się od dołu; IP nadawcy to infrastruktura atakującego, nie zasób ofiary.
- Każdy IOC należy kopiować ze źródła i weryfikować (hash liczony, nie przepisany).
- Do Timeline trafiają wyłącznie zdarzenia z dowodem; brak danych opisuje się jawnie.

12. Załączniki / Dowody

- Pełne nagłówki wiadomości (Received chain, Authentication-Results).
- Zdekodowany załącznik HTML + potwierdzenie hashy (SHA256/MD5).
- Zrzut obliczenia hashy (Python email+hashlib) jako dowód weryfikacji.
- Lista IOC z sekcji 6.

Analiza oparta wyłącznie na zweryfikowanych danych z artefaktu `training_phishing_with_detailed_headers.eml`.